

ShopSphere

S1 - Customer Authentication and Account Security

Backend + DB

Platform-Specific Sprint Planning Document

This document intentionally defines only the behavior and delivery scope of the selected platform. It does not mix implementation details from the other platforms.

1. Sprint Definition

Sprint: S1 - Customer Authentication and Account Security

Platform: Backend + DB

Application: ShopSphere

Objective: Implement complete customer registration, OTP, login, refresh, logout and password recovery as server-authoritative services.

This sprint is complete only when the stated use cases, acceptance criteria and tests pass for this platform.

2. Business Use Cases

ID	Use Case	Actor	Precondition	Main Flow	Expected Result
UC-BE-01-01	Register customer	Customer	No existing duplicate account	Validate fields, create user, issue OTP workflow	User is created in pending-verification state and OTP is tracked.
UC-BE-01-02	Verify OTP	Customer	Active OTP exists	Validate code and expiry, mark verification complete	Verification succeeds once and cannot be replayed.
UC-BE-01-03	Login	Customer	Verified account exists	Validate credentials/OTP, issue access and refresh tokens	Authenticated session is established.
UC-BE-01-04	Reset password	Customer	Valid reset OTP	Verify identity, hash new password, revoke affected sessions as configured	Password is changed and stale credentials are rejected.

3. Detailed Implementation Plan

1. Create users/roles/permissions/user_roles/refresh_tokens/otp_verifications tables.
2. Add unique indexes for email/mobile where business rules require.
3. Implement secure password hashing.
4. Implement OTP generation, hashing/storage, expiry and resend controls.
5. Implement registration and verification APIs.
6. Implement login variants.
7. Implement refresh-token rotation/revocation.
8. Implement logout and session invalidation.
9. Implement forgot/reset password.
10. Add brute-force/rate-limit controls.
11. Document API contracts and error codes.

4. Data / State / Contract Scope

- users
- roles
- permissions
- user_roles
- refresh_tokens
- otp_verifications

API / Integration Contract

- POST /api/v1/auth/register
- POST /api/v1/auth/send-otp
- POST /api/v1/auth/verify-otp

- POST /api/v1/auth/login
- POST /api/v1/auth/logout
- POST /api/v1/auth/refresh
- POST /api/v1/auth/forgot-password
- POST /api/v1/auth/reset-password
- GET /api/v1/users/me

5. Rules and Expected Behavior

- The platform must rely on the backend as the source of truth for business rules.
- Do not expose stack traces, secrets or internal implementation details to end users.
- Handle loading, empty, validation and error states explicitly.
- Requests that can be retried must be safe from duplicate side effects where the feature requires idempotency.
- Ownership and authorization must be checked server-side for protected data.

6. Acceptance Criteria

- Registration, OTP and login work end-to-end.
- Expired/invalid OTP is rejected.
- Refresh token is rotated/revoked according to policy.
- Forgot/reset password works safely.
- Rate limiting prevents brute-force abuse.
- No sensitive authentication data appears in API errors or logs.

7. Test Cases

TC	Scenario	Expected Result
TC-S1-01	Duplicate email	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S1-02	Duplicate mobile	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S1-03	Weak password	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S1-04	Wrong OTP	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S1-05	Expired OTP	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S1-06	Resend limit	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S1-07	Login failure threshold	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S1-08	Expired access token	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S1-09	Invalid refresh token	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S1-10	Replay refresh token	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S1-11	Logout then reuse token	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S1-12	Password reset with wrong OTP	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.

8. Sprint Exit Checklist

- Implementation completed only for this platform.

- All primary and negative use cases pass.
- API contracts are implemented/consumed as defined.
- Validation and authorization tests pass.
- Loading/empty/error handling is verified where applicable.
- No critical or blocker defect remains.
- Automated tests pass in CI.
- Documentation and contract changes are committed.

9. Out of Scope for This Document

- Implementation behavior of Customer Portal. That behavior belongs in the separate S1 document for that platform.
- Implementation behavior of Admin Portal. That behavior belongs in the separate S1 document for that platform.